# BÁO CÁO KIỂM THỬ MIỀN GIÁ TRỊ VÀ PHÂN TÍCH GIÁ TRỊ BIÊN

## TÍNH NĂNG FR-05: XEM DANH SÁCH & TÌM KIẾM SẢN PHẨM (MOBILE - POOL D)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform — Phân hệ Mobile (`frontend-mobile` Expo React Native / Backend API `http://localhost:3000`)
- **Kỹ thuật áp dụng:** Domain Testing (Equivalence Partitioning - EP) & Boundary Value Analysis (3-Value BVA theo chuẩn ISTQB)
- **Thời gian thực hiện:** 2026-10-18

---

## 1. ĐẶC TẢ YÊU CẦU & PHÂN TÍCH BIẾN ĐẦU VÀO (SPECIFICATION ANALYSIS)

### 1.1 Trích xuất đặc tả FR-05 từ System Requirements Specification

> - **FR-05: Xem danh sách & Tìm kiếm sản phẩm (Mobile)**
>   - Màn hình chính hiển thị danh sách tất cả sản phẩm dạng danh sách/lưới (grid/cards).
>   - Mỗi sản phẩm hiển thị: **Ảnh** (tỷ lệ chuẩn, có alt text mô tả), **Tên sản phẩm**, **Giá** (đơn vị: ₫, định dạng phân cách hàng nghìn).
>   - **Thanh tìm kiếm:** Tìm theo tên sản phẩm. Từ khóa tìm kiếm phải được **hiển thị an toàn** (không render HTML).
>   - Khi đang tải dữ liệu phải hiển thị trạng thái **loading**.
>   - Khi không có kết quả tìm kiếm phải hiển thị thông báo **empty state** phù hợp (kèm hình minh họa và thông báo rõ ràng).
>   - **Ràng buộc an ninh & phạm vi (SEC-01, SEC-04):**
>     - Từ khóa chỉ tìm kiếm trên trường Tên sản phẩm, không tìm trên Mô tả hay Danh mục.
>     - Phòng chống SQL Injection: Backend bắt buộc phải sử dụng Parameterized Query (SEC-01).
>     - Phòng chống Cross-Site Scripting (XSS): Chuỗi nhập HTML/Script phải được escape an toàn (SEC-04).

### 1.2 Điều kiện tiên quyết & Cấu hình môi trường (Preconditions & Environment Setup)

- **Backend API:** Node.js Express server chạy tại `http://localhost:3000`, CSDL SQLite `database.sqlite` đã được nạp dữ liệu mẫu (5 sản phẩm).
- **Nền tảng kiểm thử Mobile:** Chạy Expo thông qua **Web Mobile View** (`npx expo start --web` kết hợp Chrome DevTools giả lập kích thước điện thoại `iPhone 12/14 Pro` / `Samsung Galaxy`) và máy ảo **Android Studio Emulator (Pixel 6)**.
- **Xử lý sự cố kết nối mạng cục bộ (`API_URL`):**
  - Trong mã nguồn ban đầu của SUT tại [`frontend-mobile/App.js` dòng 16] (file:///c:/Users/duong/Downloads/New%20folder%20%2820%29/eshop-sut/frontend-mobile/App.js#L16), địa chỉ Backend bị gán cứng là:

    ```
    const API_URL = "http://192.168.10.13:3000/api";
    ```

  - Địa chỉ IP LAN `192.168.10.13` này không tồn tại trong mạng thử nghiệm, dẫn đến việc ứng dụng Mobile khi khởi chạy trên máy ảo Pixel 6 hoặc trên trình duyệt Web đều gặp lỗi kết nối `TypeError: Network request failed` / `Failed to fetch`, làm tê liệt toàn bộ tính năng tải danh sách và tìm kiếm sản phẩm.
  - Để phục vụ kiểm thử thực tế, tester đã chủ động can thiệp kỹ thuật vào `App.js`, cấu hình lại `API_URL` linh hoạt theo nền tảng thực thi (`Platform.OS`):

    ```
    import { Platform } from "react-native";

    const API_URL =
      Platform.OS === "android"
        ? "http://10.0.2.2:3000/api"
        : "http://localhost:3000/api";
    ```

    *(Trong đó, `10.0.2.2` là địa chỉ loopback chuẩn trỏ về máy host cho máy ảo Android Studio, và `localhost:3000` phục vụ kiểm thử trên nền tảng Web).*

### 1.3 Danh sách biến đầu vào và ràng buộc kỹ thuật

| Tên biến đầu vào | Kiểu dữ liệu | Miền giá trị hợp lệ (Valid Domain) | Ràng buộc kỹ thuật & Nghiệp vụ (Constraints) |
|---|---|---|---|
| `search_keyword` **(Từ khóa tìm kiếm)** | String | Chuỗi ký tự Unicode có độ dài từ $0$ đến $255$ ký tự. | • **Chuỗi rỗng (`""`):** Tải và hiển thị toàn bộ 5 sản phẩm.<br>• **Khớp tên:** Tìm kiếm không phân biệt hoa thường.<br>• **Phạm vi:** Chỉ tìm theo `name`, không tìm trong `description` hay `category`. |

| Tên biến đầu vào | Kiểu dữ liệu | Miền giá trị hợp lệ (Valid Domain) | Ràng buộc kỹ thuật & Nghiệp vụ (Constraints) |
|---|---|---|---|
| | | | • **An toàn:** Escape an toàn chống XSS, dùng Parameterized Query chống SQLi. |

## 2. PHÂN VÙNG TƯƠNG ĐƯƠNG (EQUIVALENCE PARTITIONING - EP)

Dựa trên hành vi xử lý của hệ thống đối với từ khóa tìm kiếm trên Mobile, phân chia miền giá trị thành các lớp tương đương:

| Biến đầu vào | Lớp tương đương | Loại | Giá trị đại diện | Mục tiêu kiểm thử |
|---|---|---|---|---|
| `search_keyword` | **EC1** | Valid | `""` (Chuỗi rỗng) | Tải toàn bộ danh sách sản phẩm mặc định khi mở app. |
| | **EC2** | Valid | `"iPhone 15 Pro Max"` | Khớp chính xác 100% tên một sản phẩm đang có trong CSDL. |
| | **EC3** | Valid | `"iPhone"` | Khớp một phần tên sản phẩm (chuỗi con - Substring). |
| | **EC4** | Valid | `"iphone"` | Khớp tên không phân biệt chữ hoa / chữ thường. |
| | **EC5** | Valid | `" iPhone "` | Có khoảng trắng thừa ở đầu/cuối (Kiểm tra cắt trim whitespace). |
| | **EC6** | Valid (Kết quả rỗng) | `"XYZ999"` | Không khớp bất kỳ sản phẩm nào (Kiểm tra hiển thị Empty State). |
| | **EC7** | Boundary / Scope | `"Điện thoại"` | Từ khóa chỉ có trong Mô tả sản phẩm, không có trong Tên (Kiểm tra phạm vi). |
| | **EC8** | Security (SQLi) | `"' OR 1=1 --"` | Chuỗi tấn công SQL Injection (Kiểm tra Parameterized Query). |
| | **EC9** | Security (Crash) | `"'"` | Dấu nháy đơn làm hỏng cú pháp SQL (Kiểm tra Error Handling / lộ mã HTML). |
| | **EC10** | Security (XSS) | `"<h1><script>alert(1)</script></h1>"` | Chuỗi chứa mã độc HTML/Script (Kiểm tra cơ chế Escape HTML của React Native). |

## 3. PHÂN TÍCH GIÁ TRỊ BIÊN (BOUNDARY VALUE ANALYSIS - 3-VALUE BVA)

Áp dụng kỹ thuật 3-Value BVA theo chuẩn ISTQB cho độ dài của chuỗi từ khóa `search_keyword` (với biên dưới $Min = 0$ ký tự và biên trên lý thuyết theo độ dài tối đa tên sản phẩm $Max = 255$ ký tự):

### 3.1 Bảng phân tích giá trị biên 3 giá trị cho FR-05

| Biến kiểm thử | Ranh giới (Boundary) | Min - 1 | Min | Min + 1 | Nominal | Max - 1 | Max | Max + 1 |
|---|---|---|---|---|---|---|---|---|
| `search_keyword.length` *(Độ dài chuỗi)* | 0 đến 255 ký tự | *N/A (Không có độ dài âm)* | `0 ký tự` (`""`) *(Valid - Tải tất cả SP)* | `1 ký tự` (`"i"`) *(Valid - Lọc SP)* | `10 ký tự` (`"iPhone 15"`) *(Valid)* | `254 ký tự` *(Valid)* | `255 ký tự` *(Valid)* | `256 ký tự` *(Valid - Empty State)* |

## 4. KẾT QUẢ THỰC THI KIỂM THỬ THỰC TẾ (TEST EXECUTION RESULTS)

Tất cả 14 kịch bản kiểm thử đã được thực thi trực tiếp trên hệ thống Mobile SUT (Expo React Native, Backend API `http://localhost:3000`, CSDL `database.sqlite`). Toàn bộ hình ảnh bằng chứng đã được lưu trữ đầy đủ tại thư mục `screenshots/fr05/`.

| Mã TC | Kịch bản kiểm thử | Dữ liệu đầu vào (Input) | Kết quả mong đợi (Expected Result) | Kết quả thực tế (Actual Result) | Trạng thái | Bằng chứng (Screenshot) | Mã lỗi (Bug ID) |
|---|---|---|---|---|---|---|---|
| **EXE-01** | Kiểm tra danh sách mặc định & Ảnh sản phẩm | `search = ""` | Tải 5 SP, giá có ₫, ảnh đúng tỷ lệ chuẩn, có alt | Giao diện Mobile tải đầy đủ 5 sản phẩm mặc định kèm giá tiền có phân cách hàng nghìn (₫). Tuy nhiên ảnh sản phẩm bị méo tỷ lệ do | **FAIL** | `EXE-01_GUI_Default_Product_List.png` | **BUG-FR05-04** |

| Mã TC | Kịch bản kiểm thử | Dữ liệu đầu vào (Input) | Kết quả mong đợi (Expected Result) | Kết quả thực tế (Actual Result) | Trạng thái | Bằng chứng (Screenshot) | Mã lỗi (Bug ID) |
|---|---|---|---|---|---|---|---|
| | | | | `resizeMode='stretch'` và không có thuộc tính alt text mô tả. | | | |
| **EXE-02** | Khớp chính xác 100% tên sản phẩm | `"iPhone 15 Pro Max"` | Trả về duy nhất 1 SP iPhone 15 Pro Max | Hệ thống tìm kiếm chính xác và hiển thị duy nhất sản phẩm iPhone 15 Pro Max với đầy đủ thông tin tên, ảnh và giá tiền 30.000.000 ₫. | **PASS** | `EXE-02_Search_Exact_Match_Success.png` | — |
| **EXE-03** | Khớp một phần tên sản phẩm (Substring) | `"iPhone"` | Trả về các SP có tên chứa 'iPhone' | Hệ thống tìm kiếm theo chuỗi con thành công, trả về sản phẩm iPhone 15 Pro Max khi nhập từ khóa 'iPhone'. | **PASS** | `EXE-03_Search_Partial_Match_Success.png` | — |
| **EXE-04** | Tìm kiếm không phân biệt hoa / thường | `"iphone"` | Trả về các SP có tên chứa 'iPhone' | Hệ thống tìm kiếm không phân biệt chữ hoa chữ thường, từ khóa 'iphone' vẫn tìm được sản phẩm 'iPhone 15 Pro Max'. | **PASS** | `EXE-04_Search_Case_Insensitive_Success.png` | — |
| **EXE-05** | Từ khóa có khoảng trắng đầu và cuối | `" iPhone "` | Tự động trim khoảng trắng và tìm thấy SP | Backend không cắt bỏ khoảng trắng thừa (untrimmed whitespace), khiến từ khóa ' iPhone ' không tìm thấy bất kỳ sản phẩm nào. | **FAIL** | `EXE-05_Bug_Untrimmed_Whitespace_Fail.png` | **BUG-FR05-02** |
| **EXE-06** | Từ khóa không tồn tại trong CSDL | `"XYZ999"` | Hiển thị giao diện Empty State thân thiện kèm hình minh họa | Khi không có kết quả tìm kiếm, giao diện Mobile hoàn toàn trắng trơn, thiếu component Empty State kèm hình ảnh minh họa theo yêu cầu của FR-05. | **FAIL** | `EXE-06_Bug_Missing_Empty_State.png` | **BUG-FR05-01** |
| **EXE-07** | Tìm theo từ khóa trong Mô tả / Danh mục | `"Điện thoại"` | Chỉ tìm theo Tên, không ra SP nào | Hệ thống tuân thủ đúng phạm vi đặc tả: chỉ tìm kiếm theo trường Tên sản phẩm, không tìm theo Mô tả (từ khóa 'Điện thoại' không khớp với tên sản phẩm nào). | **PASS** | `EXE-07_Scope_Search_Name_Only.png` | — |
| **EXE-08** | Tấn công bảo mật SQL Injection | `"' OR 1=1 --"` | Xử lý an toàn như chuỗi text, 0 kết quả | Lỗ hổng SQL Injection cực kỳ nghiêm trọng: Backend nối chuỗi trực tiếp vào câu lệnh SQL. Payload '' OR 1=1 --' làm vô hiệu hóa bộ lọc và làm lộ toàn bộ danh sách sản phẩm. | **FAIL** | `EXE-08_Bug_Critical_SQL_Injection.png` | **BUG-FR05-03** |
| **EXE-09** | Tấn công gây lỗi cú pháp SQL & Lộ mã HTML | `"'"` | Báo lỗi thân thiện 400 Bad Request | Khi nhập ký tự nháy đơn ('), Backend gặp lỗi cú pháp SQL và trả về HTTP 500 kèm mã HTML lỗi. Ứng dụng Mobile render nguyên chuỗi HTML thô lên giao diện người dùng. | **FAIL** | `EXE-09_Bug_SQL_Error_HTML_Leak.png` | **BUG-FR05-03** |
| **EXE-10** | Tấn công XSS & Thẻ | `"<h1><script>alert(1)</script></h1>"` | Escape HTML an toàn, | Hệ thống an toàn trước tấn công XSS. React Native tự động escape | **PASS** | `EXE-10_Security_XSS_Safely_Escaped.png` | — |

| Mã TC | Kịch bản kiểm thử | Dữ liệu đầu vào (Input) | Kết quả mong đợi (Expected Result) | Kết quả thực tế (Actual Result) | Trạng thái | Bằng chứng (Screenshot) | Mã lỗi (Bug ID) |
|---|---|---|---|---|---|---|---|
| | H1 trong từ khóa | | không chạy script | chuỗi thẻ HTML/script và hiển thị an toàn dưới dạng văn bản thuần. | | | |
| **EXE-11** | BVA Biên dưới Min (0 ký tự) | `""` (0 ký tự) | Tải lại toàn bộ 5 sản phẩm | Tại biên Min (0 ký tự), hệ thống tải và hiển thị lại toàn bộ danh sách 5 sản phẩm dạng danh sách card. | **PASS** | `EXE-11_BVA_Min_0_Char_All_Products.png` | — |
| **EXE-12** | BVA Biên dưới hợp lệ Min+1 (1 ký tự) | `"i"` (1 ký tự) | Trả về các SP có chữ 'i' | Tại biên Min+1 (1 ký tự 'i'), hệ thống lọc chính xác 4 sản phẩm có tên chứa chữ 'i'. | **PASS** | `EXE-12_BVA_MinPlus1_1_Char_Success.png` | — |
| **EXE-13** | BVA Biên trên hợp lệ Max (255 ký tự) | Chuỗi 255 ký tự | Tiếp nhận tốt, hiển thị Empty State | Hệ thống tiếp nhận tốt chuỗi tìm kiếm tại biên Max 255 ký tự mà không bị treo hay vỡ khung. Tuy nhiên màn hình bị trắng trơn do thiếu Empty State. | **FAIL** | `EXE-13_BVA_Max_255_Chars.png` | **BUG-FR05-01** |
| **EXE-14** | BVA Vượt biên trên Max+1 (256 ký tự) | Chuỗi 256 ký tự | Tiếp nhận tốt, hiển thị Empty State | Hệ thống không crash khi nhận chuỗi 256 ký tự (Max+1), nhưng bị lỗi giao diện trắng trơn do thiếu Empty State. | **FAIL** | `EXE-14_BVA_MaxPlus1_256_Chars.png` | **BUG-FR05-01** |

## 5. TỔNG HỢP CÁC LỖI PHÁT HIỆN (DEFECT SUMMARY)

Tổng số test cases thực thi: **14**

- **Passed:** 7/14 (50.0%)
- **Failed (Phát hiện lỗi):** 7/14 (50.0%)

Danh mục 4 nhóm lỗi phát hiện được:

1. **BUG-FR05-01 (High - Missing Empty State)**: Màn hình dưới thanh tìm kiếm hoàn toàn trắng tinh, thiếu hẳn component Empty State kèm hình minh họa và thông điệp thân thiện khi không tìm thấy sản phẩm (`EXE-06`, `EXE-13`, `EXE-14`).
2. **BUG-FR05-02 (Medium - Data Handling / Untrimmed String)**: Backend `server.js` không cắt bỏ khoảng trắng thừa đầu cuối (`trim()`), khiến từ khóa `" iPhone "` trả về 0 kết quả dù sản phẩm có tồn tại (`EXE-05`).
3. **BUG-FR05-03 (Critical - Security / SQL Injection & Raw HTML Leak)**: Backend nối chuỗi SQL trực tiếp (`WHERE name LIKE '%${searchQuery}%'`), cho phép bypass bộ lọc bằng `' OR 1=1 --` và làm sập 500 khi gặp dấu nháy `'`, văng chuỗi HTML thô `<h1>Database Error</h1>` lên màn hình Mobile (`EXE-08`, `EXE-09`).
4. **BUG-FR05-04 (Low/Medium - GUI Standards & Accessibility)**: Ảnh sản phẩm bị méo mó do cấu hình `resizeMode="stretch"` trong `App.js` dòng 460 (vi phạm yêu cầu ảnh tỷ lệ chuẩn), đồng thời thẻ `<Image>` thiếu thuộc tính `accessibilityLabel` / `alt text` mô tả ảnh (`EXE-01`).